

5. Vulnerabilidades encontradas

5.1. A01:2025 – Control de Acceso Roto (Broken Access Control)

5.1.1. A01-Omisión Crítica de Autenticación mediante Exposición de Interfaz HTTP (Puerto 80)

Descripción general.

Se ha identificado una vulnerabilidad crítica de Omisión de Autenticación (Authentication Bypass) que permite el acceso no autorizado al panel principal de la aplicación (/dashboard). El fallo radica en una inconsistencia en la aplicación de políticas de seguridad entre los puertos de servicio: mientras que el acceso vía HTTPS (443) requiere credenciales válidas, el acceso a través del puerto HTTP (80) elude por completo el formulario de inicio de sesión, otorgando acceso inmediato a las funcionalidades internas de la plataforma.

Detalles del hallazgo.

La aplicación presenta una superficie de ataque derivada de una configuración de Virtual Host o Middleware mal implementada. Al realizar una petición al puerto inseguro (<http://cootranshuila.sigemas.com:80>), el servidor no aplica los filtros de validación de identidad definidos para el tráfico cifrado. Técnicamente, al solicitar el recurso a través del puerto 80, el servidor responde con una instrucción de navegación que carga directamente el componente #/dashboard bajo el esquema seguro (HTTPS), pero sin haber pasado previamente por el proceso de validación en #/Login. Esto indica que la validación de la sesión se está realizando de forma periférica (solo en la ruta de login) y no de forma centralizada para proteger los recursos internos, permitiendo que una petición iniciada en un canal inseguro fuerce el estado de "autenticado" en la aplicación.

Impacto potencial.

- **Acceso no autorizado total:** cualquier usuario en Internet puede acceder a los datos privados del Dashboard sin poseer una cuenta de usuario o contraseña.
- **Exfiltración de datos sensibles:** un atacante puede extraer información de la aplicación y registros de clientes expuestos en el panel.
- **Manipulación de la aplicación:** un atacante podría ejecutarlas de forma anónima acciones administrativas o transaccionales, dejando a la organización vulnerable a fraude o pérdida de integridad de datos.

Técnica utilizada.

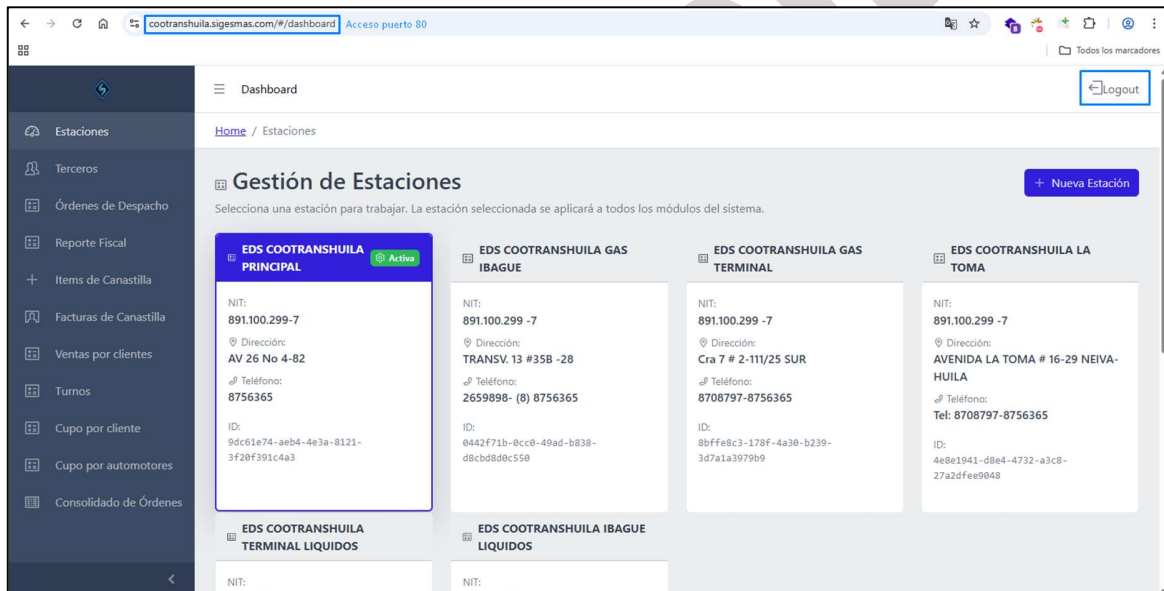
Para la identificación de esta vulnerabilidad se emplearon técnicas de Análisis de Control de Acceso (Broken Access Control Testing):

1. Enumeración de servicios: identificación del puerto 80/TCP abierto y respondiendo a peticiones HTTP.
2. Inconsistencia de protocolos: se comparó el comportamiento de la aplicación al acceder por https:// vs http://.
3. Análisis de flujo de redirección: mediante el uso de herramientas de inspección de tráfico (Browser DevTools / Burp Suite), se verificó que la solicitud al puerto 80 no generaba una redirección al /Login, sino que el servidor permitía la transición directa al estado de /dashboard en HTTPS, eludiendo la lógica de control.

Recomendaciones de mitigación.

- Redirección forzosa a nivel de servidor (HSTS): configurar el servidor web para que cualquier petición al puerto 80 sea redirigida de forma permanente (HTTP 301) a la versión HTTPS antes de procesar cualquier lógica de la aplicación.
- En la lógica de la aplicación (Frontend y Backend), se debe validar que el acceso al recurso /dashboard solo sea permitido si existe un token de sesión (JWT, Cookie de Sesión, etc.) activo y válido.
- Reconfigurar el servidor para que no sirva ningún contenido funcional a través del puerto 80, limitando este puerto exclusivamente a la redirección de tráfico hacia el puerto seguro 443.
- Revisar que el puerto 80 no tenga definida una raíz de documentos (DocumentRoot) o reglas de enrutamiento que apunten directamente a los componentes protegidos de la aplicación.

Evidencias.



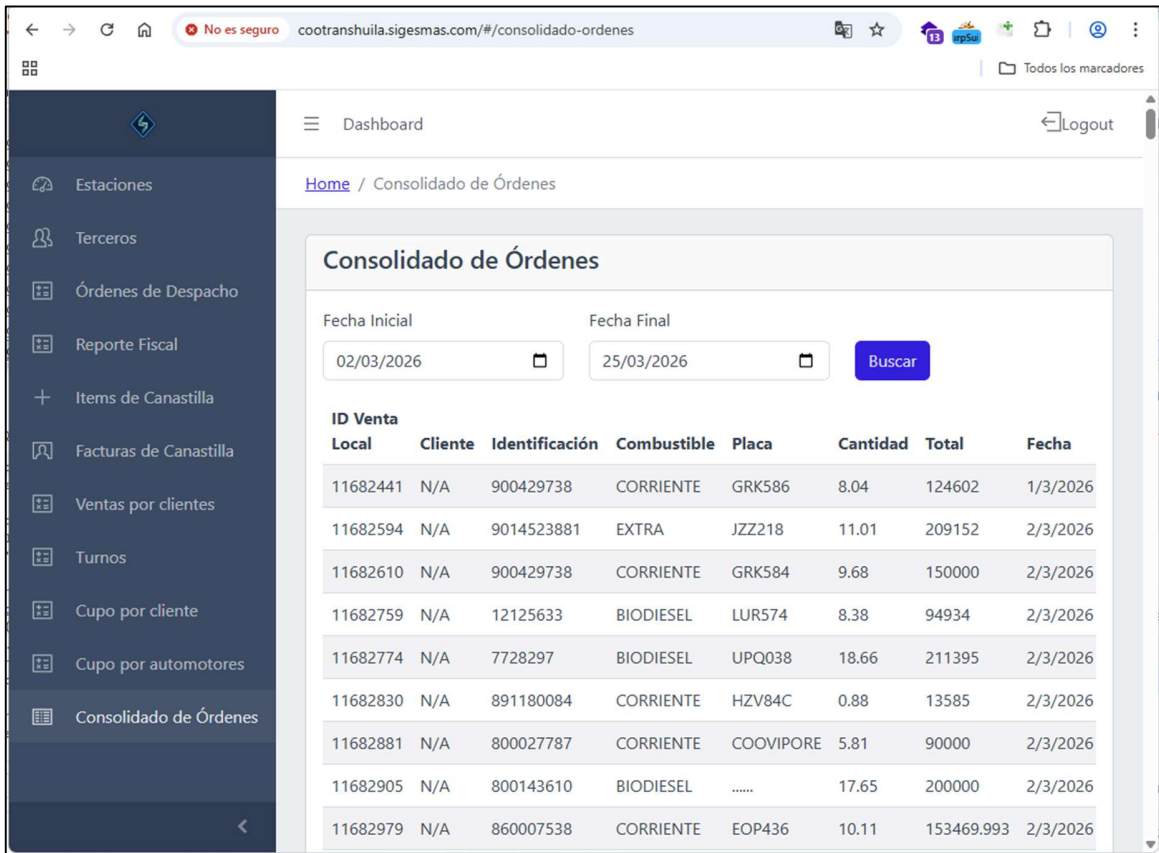


Ilustración 1. Omisión Crítica de Autenticación mediante Exposición de Interfaz HTTP (Puerto 80), en el sitio <https://cootranshuila.sigemas.com/#/Login>

5.2. A02:2025 Configuración incorrecta de seguridad (Security Misconfiguration)

5.2.1. A02-Divulgación de versiones de componentes tecnológicos

Descripción general.

Durante el análisis de seguridad, se identificó la divulgación de información sensible relacionada con los componentes tecnológicos utilizados en las aplicaciones web, información que puede ser recolectada por un atacante sin autenticación previa. Este tipo de divulgación facilita la fase de reconocimiento y enumeración durante un ataque, permitiendo a un actor malicioso identificar tecnologías específicas y correlacionarlas con vulnerabilidades conocidas.

Detalles del hallazgo.

Durante el análisis pasivo de la aplicación, se evidenció que las tecnologías pueden ser identificada de forma remota mediante el uso de herramientas de fingerprinting. Esta información se encuentra disponible para cualquier usuario que acceda al sitio, sin requerir autenticación ni privilegios especiales.